

Name : Tatenda Robin Kazonda

Email address : kazondarobin@gmail.com

AWS Security Assessment Report:

Client / Target : AWS Production Workload

Assessment Date : August 2026

Assessor : Cybersecurity Analyst

Framework : AWS Well-Architected Framework (Security Pillar) , CIS AWS Foundations Benchmark v1.5.0

Executive Summary:

A comprehensive security assessment was conducted on the target AWS cloud environment to evaluate its overall posture against established cloud security best practices. The assessment focused on identifying network exposures , identity governance gaps , storage vulnerabilities and unencrypted data assets.

The evaluation identified 5 key security findings across the target account:

- **2 Critical Severity** : Publicly accessible backup storage and privileged IAM administrative accounts operating without Multi-Factor Authentication (MFA).
- **2 High Severity** : Management ports (SSH/RDP) open globally to the internet and a production database instance exposed on a public subnet .
- **1 Medium Severity**: Unencrypted Elastic Block Store (EBS) volume containing instance data.

Immediate remediation is strongly recommended to restrict administrative network access , enforce MFA governance and eliminate public exposure of sensitive data stores.

Assessment Framework and Methodology

This assessment was conducted using the AWS Well-Architected Framework (Security Pillar) as its primary baseline , supplemented by controls from the Center for Internet Security (CIS) AWS Foundations Benchmark v3.0.

The evaluation measured security performance across five core operational domains:

1. **Identity and Access Management (IAM)** : Audit of user credentials , privileged accounts (root) , credential aging and Multi-Factor Authentication (MFA) enforcement.

2. **Infrastructure and Network Protection** : Inspection of VPC Security Group ingress rules , management interfaces and public subnet assignments.
3. **Data Protection and Encryption** : Review of server-side encryption standards for at-rest assets (S3 , EBS , RDS).
4. **Public Exposure Controls** : Assessment of account-level public access restrictions and external resource accessibility .
5. **Risk Classification** : Findings are assigned severity levels (Critical , High , Medium , Low) based on exploitability , visibility and potential business impact.

Summary of Findings

Finding ID	Vulnerable Resource	Category	Issue Description	Severity
SEC-01	sg-019a / sg-042b	Open Ports and SG Weakness	SSH (22) and RDP (3389) ingress open to 0.0.0.0/0 .	High
SEC-02	prod-user-backups-2026	Publicly Accessible Asset	S3 Block Public Access is disabled .	Critical
SEC-03	IAM : root/ admin-dev	Missing MFA / IAM Risk	Privileged accounts operating without MFA ; active root key >120 days old.	Critical
SEC-04	EBS: vol-08c3	Missing Data Encryption	Primary instance volume is unencrypted at rest.	Medium
SEC-05	RDS: db-analytics	Network Exposure	Production database assigned public IP in a public subnet.	High

Detailed Findings and Risk Analysis

SEC-01 : Ingress Management Ports Open to Global Internet

- **Affected Resources** : Security Group sg-019a (Port 22/ SSH) , Security Group sg-042b (Port 3389/ RDP)
- **Risk Analysis**: Ingress rules allowing unrestricted inbound traffic (0.0.0.0/0) on administrative ports expose server login interfaces to automated internet scanning bots. Threat actors can execute brute-force password attacks , credential stuffing or exploit

zero-day remote code execution (RCE) vulnerabilities to gain initial access to host instances.

SEC-02 : Publicly Accessible S3 Backup Storage

- **Affected Resources** : S3 Bucket `prod-user-backup-2026`
- **Risk Analysis** : Disabling “Block Public Access “ on S3 storage buckets containing user backups allows unauthenticated external access. Unauthenticated actors or search engine web crawlers can discover and exfiltrate raw database dumps , resulting in severe data breach liabilities, regulatory fines and loss of customer trust.

SEC-03 : Privileged IAM Accounts Lacking Multi-Factor Authentication

- **Affected Resources** : IAM Users `root`, `admini-dev` , Service Policy `app-service`
- **Risk Analysis** : Operating administrative accounts without mandatory MFA exposes the cloud tenant to full takeover if a password is compromised via phishing or breach dumps . Additionally , the active `root` access key is over 120 days old without rotation and the `app-service` inline policy grants excessive wildcard permissions (`iam:*` , `s3:*`) , violating least-privilege principles.

SEC-04 : Unencrypted EBS Storage Volume at Rest

- **Affected Resources** : EBS Volume `vol-08c3`
- **Risk Analysis** : Storing operational data on unencrypted block storage violates basic data compliance standards (e.g.PCI-DSS, SOC 2) . If unauthorized snapshots are created or volumes are improperly detached , underlying block data can be read without cryptographic protection.

SEC-05 : Production Database Instance Deployed in Public Subnet

- **Affected Resources**: RDS Instance `db-analytics`
- **Risk Analysis** : Assigning a public IP address and placing a database instance in a public subnet exposes database listener ports directly to internet traffic . This bypasses multi-tiered network defense , leaving the database vulnerable to network probing , denial of service and direct database exploitation.

Security Recommendations and Remediation Plan

Immediate Remediation Actions (Priority : 24-48 Hours)

1. **Block S3 Public Exposure** : Enable global *S3 Block Access* at the account level. Audit and apply explicit deny policies on bucket `prod-user-backups-2026`.
2. **Enforce IAM Governance and MFA:**
 - Enforce virtual or hardware MFA across all administrative users and the `root` account.
 - Delete or rotate access keys on the `root` account older than 90 days.
 - Remove inline policies granting `iam:*` or `s3:*` wildcards and replace them with scoped managed policies adhering to least-privilege access.
3. **Restrict Network Ingress:**
 - Revoke `0.0.0.0/0` ingress rules for ports 22 and 3389 across `sg-019a` and `sg-042b`.
 - Transition instance remote management to AWS Systems Manager Session Manager or restrict ingress to verified corporate VPN IP ranges.

Long-Term Hardening Strategy (Priority : 30 Days)

1. **Database Network Isolation** : Move `db-analytics` from the public subnet to an isolated private subnet . Disassociate its public IP and restrict security group access exclusively to inbound traffic from application tier instances .
2. **Enforce Encryption Defaults:** Enable account-level default EBS encryption using AWS KMS keys to guarantee all future volumes and guarantee all future volumes and snapshots are automatically encrypted .
3. **Automate Security Audit Guardrails:** Deploy AWS Security Hub alongside AWS Config rules to continuously audit security group changes , unencrypted resources and IAM compliance gaps in real time.